

Operación Servidor Fantasma: La Huella Invisible en la Nube

Lectura Táctica Formativa, Estudio de Caso Forense y Organizador Visual

Módulo: MTCS-20

Segundo Corte (35%)

RA 2.1: Entornos Seguros y Auditoría

Semana 06 • Sesión 01

Grupo: 501

Caso: Cryptojacking

 Narrador(a) Voz del SOC y contexto forense. Describe el ambiente de tensión y las métricas de monitoreo.	 Alex (Analista Jr.) Enfoque en hardware e identidad. Descubre el procesador Xeon y los privilegios de usuario.	 Valeria (Ciberseguridad) Especialista en sistemas de archivos y red. Inspecciona /etc y triangula geolocalización satelital.	 El Profesor Guía metodológico del Blue Team. Formula las preguntas críticas de auditoría y valida las evidencias.
--	--	--	---

ACTO 1 La Alarma Térmica y la Factura Imposible

NARRADOR Son las 15:10 horas en el laboratorio de cómputo de CONALEP Plantel Pachuca de Soto. En la consola de monitoreo del rack en la nube parpadea una baliza ámbar que en segundos cambia a rojo escarlata. La telemetría marca un consumo energético anormal.

ALEX —Profesor, mire los gráficos del clúster escolar en Google Cloud. Nuestra máquina virtual Debian marca 100% de uso de procesador ininterrumpido desde las 3:00 AM. La alerta del proveedor advierte que el consumo de potencia se triplicó.

VALERIA —Es ilógico. El taller cerró ayer a las siete de la tarde y nadie tiene tareas de renderizado ni bases de datos activas. Entré al portal del módulo y no hay archivos cifrados, ni notas pidiendo rescate en criptomonedas. Si no destruyeron nada... ¿por qué el servidor está hirviendo?

PROFESOR —Porque no todos los atacantes buscan destruir, Valeria. En el mundo corporativo existe una amenaza mucho más rentable y sigilosa: el *Cryptojacking*. Los cibercriminales no secuestran tus datos; secuestran la potencia eléctrica y de cálculo de tu procesador para minar criptomonedas a tus expensas.

ACTO 2 El Abismo Headless: El Universo sin Ratón

NARRADOR Alex abre una sesión de conexión remota hacia la instancia afectada. En el proyector de la clase no aparece un escritorio de Windows con iconos coloridos ni menús desplegables. Solo una pantalla de fondo negro absoluto con un cursor rectangular parpadeante.

```
usuario@cloudshell:~$ _ (Debian GNU/Linux 12 - Google Cloud Shell)
```

VALERIA —Bienvenidos al mundo de los servidores profesionales: modo *Headless*. En ciberseguridad defensiva no se instalan interfaces gráficas en servidores porque consumirían valiosa memoria RAM y ampliarían la superficie de ataque. Aquí no hay ratón. Todo se investiga mediante la shell de Bash.

ALEX —Si el intruso desplegó un contenedor de minería oculto, tuvo que dejar rastros en la tabla de procesos y en las variables del entorno. Es hora de desplegar la batería de reconocimiento pericial.

ACTO 3 Fase 1 — Identidad, Permisos y Carga del Sistema

NARRADOR Valeria coloca los dedos sobre el teclado mecánico y ejecuta la primera fase del protocolo forense: verificar con qué nivel de privilegios están operando y cuánto tiempo lleva asfixiada la máquina.

```
usuario@cloudshell:~$ whoami && id
usuario
uid=1000(usuario) gid=1000(usuario) groups=1000(usuario),4(adm),27(sudo)
usuario@cloudshell:~$ uptime
15:12:44 up 14:18, 1 user, load average: 4.88, 4.75, 4.60
```

VALERIA —Primer hallazgo: nuestro identificador es UID 1000. No somos el superusuario root (UID 0). Eso significa que el atacante no modificó los binarios del núcleo del kernel, pero sí logró ejecutar scripts en segundo plano.

ALEX —Miren el resultado de uptime. El *load average* está en 4.88. En un servidor con 4 núcleos lógicos, cualquier valor superior a 4.00 significa saturación total: hay procesos encolados esperando procesador. ¡El minero está devorando ciclos de cómputo en este milisegundo!

ACTO 4 Fase 2 — La Revelación del Hardware de Servidor

NARRADOR Alex toma el control del teclado. Quiere entender por qué un ciberdelincuente se molestaría en atacar una máquina escolar en vez de infectar computadoras domésticas. Lanza la orden de auditoría de arquitectura de hardware.

```
usuario@cloudshell:~$ lscpu | grep -E "Model name|CPU(s):"
CPU(s): 4
Model name: Intel(R) Xeon(R) CPU @ 2.80GHz
usuario@cloudshell:~$ free -h
total used free shared buff/cache available
Mem: 15Gi 14Gi 420Mi 12Mi 780Mi 850Mi
```

ALEX —¡Aquí está la respuesta! Procesadores empresariales **Intel Xeon** en la infraestructura de Google Cloud con 16 Gigabytes de memoria RAM. A los atacantes no les sirven las laptops lentas; buscan la nube porque un solo servidor Xeon genera más bloques de criptomonedas en un día que una oficina entera en un mes.

PROFESOR —Exacto. Las organizaciones pagan miles de dólares por poder de procesamiento en la nube. Cuando un atacante comete cryptojacking, la víctima no solo sufre lentitud: la factura del proveedor de nube puede arruinar el presupuesto operativo de una empresa.

ACTO 5 Fase 3 — Infiltración en el Directorio Raíz (/etc)

NARRADOR Valeria navega hacia el cerebro administrativo de Linux: el directorio `/etc`, donde residen los archivos que definen qué usuarios existen y qué permisos tienen para entrar al sistema.

```
usuario@cloudshell:~$ cat /etc/os-release | grep "PRETTY_NAME"
PRETTY_NAME="Debian GNU/Linux 12 (bookworm)"
usuario@cloudshell:~$ cat /etc/passwd | tail -n 6
sshd:x:106:65534:./run/sshd:/usr/sbin/nologin
tcpdump:x:107:112:./nonexistent:/usr/sbin/nologin
usuario:x:1000:1000:Google Cloud Shell User:/home/usuario:/bin/bash
```

VALERIA —Confirmamos que corremos sobre **Debian GNU/Linux 12 (Bookworm)**. Al revisar `/etc/passwd`, notamos que casi todas las cuentas de servicio terminan en `/usr/sbin/nologin`. Esto significa que nadie puede iniciar sesión interactiva con ellas. La única shell real con `/bin/bash` es la nuestra.

ALEX —Eso demuestra que el intruso no logró crear una cuenta oculta permanente con contraseña. Su ataque está corriendo como un proceso huérfano dentro de la carpeta `/home/usuario` o en un contenedor efímero.

ACTO 6 Fase 4 — La Paradoja de la Doble IP (Privada vs Pública)

NARRADOR Para detener la fuga de información, el equipo necesita saber hacia dónde se envían los datos. Alex ejecuta el comando de consulta de interfaces de red internas.

```
usuario@cloudshell:~$ hostname -I
10.88.0.4
usuario@cloudshell:~$ curl -s ifconfig.me
34.125.74.198
```

ALEX —Miren esto: `hostname -I` nos entrega `10.88.0.4`. Esa es una dirección privada Clase A. Está encapsulada dentro de la red virtual de Google; no existe en el internet público. ¿Cómo se comunica el minero con el servidor atacante en el exterior?

VALERIA —A través de la pasarela de traducción NAT. Por eso usamos `curl -s ifconfig.me`. Al interrogar a un servidor externo en internet, descubrimos la IP pública real que Google le asignó a nuestra conexión de salida: **34.125.74.198**.

ACTO 7 Fase 5 — Triangulación Satelital del Centro de Datos

NARRADOR Valeria abre el navegador del taller e ingresa la IP pública en el portal de geolocalización de telecomunicaciones `iplocation.io`. En segundos, una retícula satelital se posiciona sobre un punto geográfico en el mapa mundial.

REPORTE DE TELEMETRÍA GEOESPACIAL (IPLOCATION.IO)

Dirección IPv4 Pública: 34.125.74.198 | **Proveedor (ISP):** Google Cloud Platform

Ubicación Física del Data Center: Council Bluffs, Iowa, Estados Unidos de América.

Latencia a Google DNS (8.8.8.8): 0.742 ms (enlace de fibra óptica troncal interoceánica).

VALERIA —¡Localizado con precisión! Nuestra terminal de Cloud Shell no está en México; se ejecuta en una granja de servidores de Google en Iowa, Estados Unidos. El malware estaba enviando hashes criptográficos hacia un pool minero en el extranjero.

ACTO 8 El Dictamen Pericial en nano y la Misión de Laboratorio

ALEX —No podemos apagar el equipo sin dejar registro formal. En la terminal abro el editor de texto plano: `nano bitacora_forense.txt`. Documentamos cada comando, la IP detectada y el procesador Xeon identificado. Con `Ctrl + O` guardamos y con `Ctrl + X` cerramos el archivo.

PROFESOR —Excelente trabajo de respuesta a incidentes, equipo. Han actuado como un verdadero Blue Team: identificaron la anomalía, auditaron el hardware, revisaron los usuarios y rastrearon la red sin depender de un ratón. Ahora, plasmen el organizador visual en su libreta para que quede sellado el peritaje técnico. En la próxima sesión, cada uno de ustedes entrará a su propia terminal a reproducir esta investigación.



ORGANIZADOR VISUAL FORENSE: ANATOMÍA DEL INCIDENTE EN LA NUBE

Instrucción para el alumno: Reproduce en tu libreta el siguiente esquema de 3 columnas como evidencia de la Sesión 01.

1. VECTOR DE ATAQUE

- **Tipo de amenaza:** Cryptojacking silencioso.
- **Modo de operación:** Intrusión en contenedor de nube.
- **Objetivo del atacante:** Robo de ciclos de procesador para minería.
- **Diferencia con Ransomware:** No destruye ni cifra; parasita los recursos.

2. SÍNTOMAS TÉCNICOS

- **CPU y RAM:** Consumo del 100% sostenido.
- **Uptime crítico:** Load average superior a 4.00.
- **Alarma financiera:** Incremento en la factura de la nube.
- **Entorno Headless:** Servidor remoto Debian operado exclusivamente por consola.

3. RESPUESTA FORENSE (LINUX)

- **Identidad:** `whoami` e `id` (permisos UID 1000).
- **Hardware:** `lscpu` (Intel Xeon) y `free -h`.
- **Sistema:** `cat /etc/os-release` y `/etc/passwd`.
- **Red:** `hostname -I` (privada) vs `curl ifconfig.me` (pública).
- **Dictamen:** Registro en `nano bitacora.txt` y `grep`.



CUESTIONARIO DE CONTROL DE LECTURA (RESPONDER EN LIBRETA)

1. ¿Cuál es la diferencia fundamental entre un ataque de **Ransomware** y uno de **Cryptojacking**?
2. ¿Qué significa que un servidor en la nube opere en **modo «Headless»** y por qué se prefiere en ciberseguridad?
3. ¿Por qué a los atacantes les interesa comprometer servidores con procesadores **Intel Xeon** en vez de computadoras personales?
4. ¿Por qué el comando `hostname -I` muestra una dirección como **10.88.0.4** y se requiere `curl ifconfig.me` para ver la IP pública?
5. ¿Cuáles son los atajos de teclado esenciales en el editor `nano` para guardar los cambios y salir a la shell?

Evidencia formativa Sesión 01: Lectura comprensiva, organizador visual dibujado en libreta y respuestas al cuestionario.

CONALEP Plantel Pachuca de Soto • Módulo MTCS-20 • Segundo Corte • RA 2.1

SELLO DEL DOCENTE